

Luiss

Libera Università Internazionale
degli Studi Sociali Guido Carli

NIS2: EU Cybersecurity for Essential and Important Entities

Data Privacy and Security

Data Science and Management (DASMA)

LUISS



Where NIS2 Fits in the EU Cyber Stack



What you already know from previous lectures

From R01 (Regulations overview)

- The EU uses a **layered** cyber+privacy architecture: GDPR, ePrivacy, NIS2, Cybersecurity Act, DORA, CRA, AI Act
- NIS2 is a **directive** (Member States must transpose it into national law)
- It is about **cyber governance**, not personal-data rights

From the GDPR guest lecture

- GDPR governs *personal-data* processing (controllers, processors, data subjects)
- 72-hour breach notification under Art. 33 GDPR
- DPAs as enforcement authorities, fines up to 4% global turnover

NIS2 builds on **the same incident**, but asks **different questions**.

Why a dedicated NIS2 lecture

NIS2 is the EU's **horizontal cybersecurity law** for organizations that society depends on.

It deserves its own lecture because:

- It defines **who** in the economy must run a real cybersecurity programme
- It fixes a **minimum content** for that programme (Art. 21)
- It defines **incident reporting** with sub-day deadlines (Art. 23)
- It makes **boards personally accountable** (Art. 20)
- It sets a **supervision and sanctions** regime that is much closer to GDPR than to the original NIS

Why a dedicated NIS2 lecture

NIS2 is the EU's **horizontal cybersecurity law** for organizations that society depends on.

It deserves its own lecture because:

- It defines **who** in the economy must run a real cybersecurity programme
- It fixes a **minimum content** for that programme (Art. 21)
- It defines **incident reporting** with sub-day deadlines (Art. 23)
- It makes **boards personally accountable** (Art. 20)
- It sets a **supervision and sanctions** regime that is much closer to GDPR than to the original NIS

Mental model: GDPR is *data-protection law that happens to require security*. NIS2 is *cybersecurity law that happens to involve some data*.

NIS2 in one slide

NIS2 – Directive (EU) 2022/2555, *Network and Information Security 2*.

- Adopted: 14 December 2022; in force: 16 January 2023
- Transposition deadline: **17 October 2024**
- Applicable from: **18 October 2024**
- Replaces NIS1 (Directive (EU) 2016/1148)
- Scope: 18 sectors, tens of thousands of entities across the EU
- Italian transposition: **D.Lgs. 138/2024**, supervised by **ACN** (Agenzia per la Cybersicurezza Nazionale)

NIS2 in one slide

NIS2 – Directive (EU) 2022/2555, *Network and Information Security 2*.

- Adopted: 14 December 2022; in force: 16 January 2023
- Transposition deadline: **17 October 2024**
- Applicable from: **18 October 2024**
- Replaces NIS1 (Directive (EU) 2016/1148)
- Scope: 18 sectors, tens of thousands of entities across the EU
- Italian transposition: **D.Lgs. 138/2024**, supervised by **ACN** (Agenzia per la Cybersicurezza Nazionale)

A directive is not directly binding on companies. The text that actually applies to an Italian entity is **D.Lgs. 138/2024**, plus ACN's implementing acts. NIS2 is the *blueprint* that this national law must respect.

From NIS1 to NIS2



NIS1 (2016): a first attempt with known limits

The original **NIS Directive** (2016/1148) was the EU's first horizontal cyber law. It introduced two useful ideas – and several problems.

What worked:

- The concept of **OES** (Operators of Essential Services) and **DSPs** (Digital Service Providers)
- National **CSIRTs** and a **Cooperation Group** between Member States

What did not work:

- **Inconsistent identification** of OES across Member States – the same airline could be in scope in one country and out in another
- **Narrow scope**: many critical sectors (public administration, food, waste, space, manufacturing) were excluded
- **Weak enforcement**: low and uneven sanctions; no strong board accountability
- **Vague obligations**: *appropriate measures*, with no minimum list

What changed between 2016 and 2022

Threat landscape

- Industrial-scale **ransomware** (WannaCry, NotPetya, Colonial Pipeline)
- **Supply-chain** attacks (SolarWinds, Kaseya, Log4Shell)
- **State-sponsored** intrusions in healthcare, energy, government
- War in Ukraine: cyber as a **dimension of conflict**

Policy lessons

- A short list of *critical sectors* is no longer enough
- *Soft* obligations on management do not change behavior
- Reporting deadlines must be **harmonized** to be useful
- **Supply-chain** risk is now a regulatory subject, not a procurement detail

NIS2's strategic objectives

NIS2 is built around four explicit goals:

- **Wider coverage:** more sectors, more entity types, more uniform thresholds
- **Higher baseline:** a fixed minimum set of risk-management measures (Art. 21)
- **Stronger enforcement:** GDPR-style fines, supervisory powers, and personal liability
- **Better cooperation:** structured incident reporting, EU-CyCLONe, CSIRTs Network, vulnerability database at ENISA

NIS2's strategic objectives

NIS2 is built around four explicit goals:

- **Wider coverage:** more sectors, more entity types, more uniform thresholds
- **Higher baseline:** a fixed minimum set of risk-management measures (Art. 21)
- **Stronger enforcement:** GDPR-style fines, supervisory powers, and personal liability
- **Better cooperation:** structured incident reporting, EU-CyCLONe, CSIRTs Network, vulnerability database at ENISA

NIS2 still leaves a lot to **national law**: thresholds, exact reporting templates, sector-specific rules, and the choice of competent authorities. Always read NIS2 *together with* the national transposition that applies to you.

NIS2 timeline

Date	Event
14 Dec 2022	NIS2 adopted by EU Parliament and Council
16 Jan 2023	NIS2 enters into force
17 Oct 2024	Deadline for Member States to transpose into national law
18 Oct 2024	NIS2 obligations apply
Within transposition	Member States compile list of essential and important entities
17 Apr 2025	Lists of entities communicated to the Commission
17 Oct 2027	Commission's first review of NIS2

Who Is in Scope



Two categories of regulated entities

Essential entities (Annex I)

Sectors with the highest societal impact:

- Energy
- Transport
- Banking & financial market infrastructures
- Health
- Drinking water & wastewater
- Digital infrastructure (DNS, TLD, IXP, cloud, data centers, CDNs, trust services, public e-comms)
- ICT service management (B2B)
- Public administration (central, regional)
- Space

Important entities (Annex II)

Other sectors that are critical but with somewhat lower systemic impact:

- Postal & courier services
- Waste management
- Manufacture, production & distribution of chemicals
- Production, processing & distribution of food
- Manufacturing (medical devices, electronics, machinery, motor vehicles, etc.)
- Digital providers (online marketplaces, search engines, social networks)
- Research organisations

Essential vs important: why the distinction matters

The split is **not about the obligations** – they are largely the same. It is about **how strictly** the State watches you.

Aspect	Essential entities	Important entities
Risk-management obligations (Art. 21)	Yes	Yes
Incident reporting obligations (Art. 23)	Yes	Yes
Supervision regime	Ex-ante: regular audits, inspections, scans	Ex-post: only after evidence of non-compliance
Maximum fine	€10M or 2% of worldwide turnover	€7M or 1.4% of worldwide turnover
Personal sanctions on management	Suspension possible	Not foreseen

Essential vs important: why the distinction matters

The split is **not about the obligations** – they are largely the same. It is about **how strictly** the State watches you.

Aspect	Essential entities	Important entities
Risk-management obligations (Art. 21)	Yes	Yes
Incident reporting obligations (Art. 23)	Yes	Yes
Supervision regime	Ex-ante: regular audits, inspections, scans	Ex-post: only after evidence of non-compliance
Maximum fine	€10M or 2% of worldwide turnover	€7M or 1.4% of worldwide turnover
Personal sanctions on management	Suspension possible	Not foreseen

Practical consequence: an essential entity should expect to be audited and tested even *without* an incident. An important entity gets the regulator's attention mostly *after* something goes wrong.

The size-cap rule

Default rule (Art. 2(1)): NIS2 applies to entities in Annex I or II that are at least **medium-sized** under EU recommendation 2003/361:

- **Medium:** 50–249 employees *and* annual turnover $\leq$ €50M *or* balance sheet $\leq$ €43M
- **Large:** $\geq$ 250 employees, or turnover $>$ €50M and balance sheet $>$ €43M

Small ($<$ 50 employees, $\leq$ €10M) and **micro** ($<$ 10 employees, $\leq$ €2M) entities are **out of scope by default**.

The size-cap rule

Default rule (Art. 2(1)): NIS2 applies to entities in Annex I or II that are at least **medium-sized** under EU recommendation 2003/361:

- **Medium:** 50–249 employees *and* annual turnover $\leq$ €50M *or* balance sheet $\leq$ €43M
- **Large:** $\geq$ 250 employees, or turnover $>$ €50M and balance sheet $>$ €43M

Small ($<$ 50 employees, $\leq$ €10M) and **micro** ($<$ 10 employees, $\leq$ €2M) entities are **out of scope by default**.

The size-cap rule is the **default**, not an absolute. Several categories fall in scope **regardless of size** (next slide).

Size-cap exceptions: in scope regardless of size

Art. 2(2)–(3) NIS2 keep small and micro entities **in scope** when their failure would still hurt society or critical sectors. Examples:

- **Providers of public electronic communications networks or services**
- **Trust service providers** (e.g., qualified certificate issuers)
- **TLD name registries and DNS service providers** (excluding root server operators)
- **Sole providers** of an essential service in a Member State
- Entities whose disruption could have a **significant impact on public safety, public security, or public health**
- Entities whose disruption could induce **systemic risk**, especially with cross-border effects
- **Critical entities** identified under the **CER Directive** (2022/2557)
- **Public administration entities** as defined by the Member State

Extraterritorial reach and registration

Where you are *established* for NIS2

- Generally: where the **main establishment** is – the Member State where cybersecurity decisions are predominantly taken
- For DNS, TLDs, cloud, data centers, CDNs, ICT service management, online marketplaces, search engines, social networks: where the **main establishment** in the EU is, or where a **representative** has been designated if outside the EU

Registration duty (Art. 27)

- Most digital infrastructure / digital provider categories must **register** with the competent authority of their main establishment
- Information required: name, address, sector, contact, IP ranges, Member States where services are offered
- ENISA maintains a **central registry**
- Failing to register is itself a sanctionable infringement

Italian transposition: D.Lgs. 138/2024 in one slide

Italy transposed NIS2 with **Decreto Legislativo 4 settembre 2024, n. 138**, in force from **16 October 2024**.

Key points:

- The competent national authority is **ACN** (Agenzia per la Cybersicurezza Nazionale)
- The **CSIRT Italia** receives incident notifications
- Italian-specific list of in-scope sectors and sub-sectors, broadly aligned with Annex I/II
- A **registration platform** managed by ACN; entities had to self-register by **28 February 2025** for the first cycle
- Implementing decrees define **proportionality**, security measures, and reporting templates
- Italian fines mirror NIS2 maxima but ACN can also issue **warnings, formal injunctions and binding instructions**

Italian transposition: D.Lgs. 138/2024 in one slide

Italy transposed NIS2 with **Decreto Legislativo 4 settembre 2024, n. 138**, in force from **16 October 2024**.

Key points:

- The competent national authority is **ACN** (Agenzia per la Cybersicurezza Nazionale)
- The **CSIRT Italia** receives incident notifications
- Italian-specific list of in-scope sectors and sub-sectors, broadly aligned with Annex I/II
- A **registration platform** managed by ACN; entities had to self-register by **28 February 2025** for the first cycle
- Implementing decrees define **proportionality**, security measures, and reporting templates
- Italian fines mirror NIS2 maxima but ACN can also issue **warnings, formal injunctions and binding instructions**

If you work for an Italian organization, NIS2 is operationally **D.Lgs. 138/2024 + ACN guidelines**. The European text mainly fixes what those national rules cannot contradict.

Case study: are universities in scope?

NIS2 itself does **not** automatically cover universities – but the Italian transposition does, via a dedicated category.

At EU level (NIS2)

- Annex II includes *research organisations*, but Art. 6(41) defines them as entities focused on **commercially exploitable** applied research and **explicitly excludes educational institutions**
- Recital 36 leaves Member States free to extend the scope to universities that **carry out critical research**

At Italian level (D.Lgs. 138/2024)

- Italy used that discretion: **Allegato IV** of the decree adds the category *Istituti di istruzione che svolgono attività di ricerca*
- Universities performing research are therefore in scope as **important entities** in the public-administration / research perimeter
- A university hospital is **separately** in scope as **essential entity** under *Health* (Allegato I)
- The **Rettore** registers the university on ACN's platform; ACN issues a **Determinazione** that formally lists the institution

Case study: are universities in scope?

NIS2 itself does **not** automatically cover universities – but the Italian transposition does, via a dedicated category.

At EU level (NIS2)

- Annex II includes *research organisations*, but Art. 6(41) defines them as entities focused on **commercially exploitable** applied research and **explicitly excludes educational institutions**
- Recital 36 leaves Member States free to extend the scope to universities that **carry out critical research**

At Italian level (D.Lgs. 138/2024)

- Italy used that discretion: **Allegato IV** of the decree adds the category *Istituti di istruzione che svolgono attività di ricerca*
- Universities performing research are therefore in scope as **important entities** in the public-administration / research perimeter
- A university hospital is **separately** in scope as **essential entity** under *Health* (Allegato I)
- The **Rettore** registers the university on ACN's platform; ACN issues a **Determinazione** that formally lists the institution

Italy explicitly extended NIS2 scope to research-performing universities via **Allegato IV** of D.Lgs. 138/2024 – a power Recital 36 leaves to Member States.

Article 21: Risk-Management Measures



Art. 21: an explicit minimum, not a wish list

Unlike NIS1, NIS2 lists the **minimum measures** that every essential or important entity must implement (Art. 21(2)). Ten categories, all mandatory:

- (a) Risk analysis & information security policies
- (b) Incident handling
- (c) Business continuity, backup management, crisis management
- (d) Supply-chain security
- (e) Security in network/IS acquisition, development, and maintenance, including vulnerability handling and disclosure
- (f) Policies & procedures to assess effectiveness of measures
- (g) Basic cyber hygiene practices and cybersecurity training
- (h) Policies on use of cryptography and, where appropriate, encryption
- (i) Human-resources security, access-control policies, asset management
- (j) Use of MFA, secured voice/video/text, and secured emergency comms where appropriate

All-hazards and proportionality

All-hazards approach (Art. 21(1))

Measures must protect networks and information systems from any event that could harm them, including:

- cyber attacks
- physical & environmental incidents
- system failures and human errors
- malicious or accidental insider actions

Proportionality

Measures must be appropriate to:

- the **risks posed** to the network and information systems
- the **size** of the entity
- the **likelihood** of incidents and their **severity**
- the **state of the art** and cost of implementation

Proportionality does **not** allow skipping any of the ten categories – only calibrating their depth.

Risk analysis and ISMS-style policies

Art. 21(2)(a) requires a documented, periodic risk analysis and a set of information-security policies. In practice this aligns with ISO/IEC 27001 / NIST CSF logic:

- **Asset inventory:** hardware, software, data, services, suppliers
- **Threat & vulnerability identification:** relevant scenarios for the sector
- **Risk assessment:** likelihood × impact, with a defined risk-acceptance threshold
- **Risk treatment plan:** mitigations, residual risks, ownership, deadlines
- **Policy hierarchy:** top-level information-security policy approved by management, then domain policies (access, crypto, supplier, BCM, ...)
- **Periodic review:** at least annually and after significant changes or incidents

Incident handling, BCM, and crisis management

Incident handling – Art. 21(2)(b)

- Documented IR process: detect, contain, eradicate, recover, post-mortem
- Roles, escalation paths, on-call rotation
- Logging & forensic preservation aligned with reporting deadlines
- Coordination with the national CSIRT and law enforcement

Continuity & crisis – Art. 21(2)(c)

- **BCP / DRP** with RTO/RPO consistent with the criticality of the service
- **Backup management**: tested restores, offline/immutable copies against ransomware
- **Crisis-management** plan covering communication, decision-making, regulator interaction
- Periodic **exercises** (table-top, simulations)

Supply-chain security

Art. 21(2)(d) and Art. 22 turn supply-chain risk into a regulated activity. Entities must consider:

- **Specific vulnerabilities** of each direct supplier and service provider
- The **overall quality** of supplier products and cybersecurity practices, including their secure development procedures
- The **results of EU-coordinated risk assessments** of critical supply chains (Art. 22)

Operational consequences:

- **Cybersecurity clauses** in contracts (security measures, audit rights, incident notification, sub-processors)
- **Onboarding due diligence**: questionnaires, certifications (e.g., ISO 27001, SOC 2), penetration test summaries
- A **register of critical suppliers** with risk classification and exit strategy
- **Continuous monitoring**: security ratings, breach feeds, contract reviews

Supply-chain security

Art. 21(2)(d) and Art. 22 turn supply-chain risk into a regulated activity. Entities must consider:

- **Specific vulnerabilities** of each direct supplier and service provider
- The **overall quality** of supplier products and cybersecurity practices, including their secure development procedures
- The **results of EU-coordinated risk assessments** of critical supply chains (Art. 22)

Operational consequences:

- **Cybersecurity clauses** in contracts (security measures, audit rights, incident notification, sub-processors)
- **Onboarding due diligence**: questionnaires, certifications (e.g., ISO 27001, SOC 2), penetration test summaries
- A **register of critical suppliers** with risk classification and exit strategy
- **Continuous monitoring**: security ratings, breach feeds, contract reviews

An incident at a supplier that affects the regulated entity is the regulated entity's incident to report. Outsourcing a service does not outsource NIS2 accountability.

Secure development and vulnerability handling

Art. 21(2)(e) covers the full life cycle of network and information systems:

- **Secure development:** threat modeling, secure coding, code review, SAST/DAST, dependency scanning, hardened build pipelines
- **Acquisition:** security requirements in tenders, evaluation of vendor security posture, secure configuration baselines
- **Maintenance:** patch management with documented SLAs, change management with security review
- **Vulnerability handling:** a **coordinated vulnerability disclosure (CVD)** policy, internal triage process, public point of contact
- **ENISA's European vulnerability database** (Art. 12) provides an EU-level coordination point

Cyber hygiene, training, MFA, cryptography

Hygiene & training – (g)

- Phishing-resistant authentication
- Patching & configuration baselines
- Backup hygiene
- Onboarding & periodic security training for all staff
- **Targeted training for management** (Art. 20(2))

Crypto, IAM, MFA – (h), (i), (j)

- Documented **cryptography policy**: algorithms, key lengths, key management, encryption at rest and in transit
- **IAM**: least privilege, role-based access, joiner/mover/leaver workflows
- **MFA** for privileged access, remote access, and where appropriate for end-users
- Secured emergency communications when normal channels are degraded

Effectiveness assessment: closing the loop

Art. 21(2)(f) demands not only measures, but also a way to know whether they work.

Typical instruments:

- **KPIs / KRIs** for security operations (MTTD, MTTR, patch SLA compliance, phishing click rate)
- **Internal audits** of the ISMS
- **External assessments**: penetration tests, red-team exercises, vulnerability scans
- **Tabletop exercises** for crisis-management plans
- **Management reviews**: periodic board-level review of risk posture and incident metrics

Effectiveness assessment: closing the loop

Art. 21(2)(f) demands not only measures, but also a way to know whether they work.

Typical instruments:

- **KPIs / KRIs** for security operations (MTTD, MTTR, patch SLA compliance, phishing click rate)
- **Internal audits** of the ISMS
- **External assessments**: penetration tests, red-team exercises, vulnerability scans
- **Tabletop exercises** for crisis-management plans
- **Management reviews**: periodic board-level review of risk posture and incident metrics

An organization without measurable evidence of *effectiveness* will struggle to defend itself in a NIS2 audit, even if individual controls exist. "We have a firewall" is not the answer to "is it working?".

Incident Reporting (Art. 23)



What counts as a *significant incident*

Art. 23(3) defines a **significant incident** as one that:

- has **caused or is capable of causing severe operational disruption** of the services or financial loss for the entity, **or**
- has **affected or is capable of affecting other natural or legal persons** by causing considerable material or non-material damage

Implications:

- A **near-miss** can be reportable if it *could have* caused severe disruption
- The threshold is **service-impact-based**, not malware-detection-based
- Sector-specific implementing acts give **quantitative thresholds** (downtime, users affected, financial loss)

The three-step reporting timeline

Art. 23(4) defines a structured cascade:

Step	Deadline	Content
Early warning	within 24 h of becoming aware	whether the incident is suspected to be unlawful/malicious; possible cross-border impact
Incident notification	within 72 h of becoming aware	initial assessment, severity & impact, IoCs
Intermediate report	on request by CSIRT/authority	status update
Final report	within 1 month after incident notification	detailed description, root cause, mitigations applied, cross-border impact
Progress report	if incident is ongoing at 1 month	status, with a final report once incident is closed

The three-step reporting timeline

Art. 23(4) defines a structured cascade:

Step	Deadline	Content
Early warning	within 24 h of becoming aware	whether the incident is suspected to be unlawful/malicious; possible cross-border impact
Incident notification	within 72 h of becoming aware	initial assessment, severity & impact, IoCs
Intermediate report	on request by CSIRT/authority	status update
Final report	within 1 month after incident notification	detailed description, root cause, mitigations applied, cross-border impact
Progress report	if incident is ongoing at 1 month	status, with a final report once incident is closed

The clock starts when the entity **becomes aware** of the incident – typically when its SOC or IT operations recognize that an event meets the significance threshold. It does **not** start at containment or final root-cause analysis.

Whom you notify, and to whom you talk

Authorities

- **CSIRT** (Computer Security Incident Response Team) of the Member State of main establishment
- The **competent authority**, if national law designates one in addition
- For cross-border incidents: other affected CSIRTs through the **CSIRTs Network**
- **ENISA** receives summary information for the EU-level picture

Recipients of services

- **Without undue delay**, recipients potentially affected by a significant cyber threat must be informed of measures or remedies they can take (Art. 23(2))
- Where appropriate, the **public** must be informed of the incident (Art. 23(11))
- This sits **alongside** GDPR Art. 34 obligations to inform data subjects when there is high risk to their rights

Coexistence with GDPR breach notification

An incident may trigger **both** NIS2 and GDPR notifications. They are **not substitutes**:

Aspect	GDPR Art. 33–34	NIS2 Art. 23
Trigger	Personal-data breach	Significant cyber incident
First deadline	72 h notification to DPA	24 h early warning to CSIRT
Audience	DPA, data subjects	CSIRT / competent authority, recipients of services, public
Question asked	Were data-subject rights at risk?	Were services and infrastructure resilient?

Coexistence with GDPR breach notification

An incident may trigger **both** NIS2 and GDPR notifications. They are **not substitutes**:

Aspect	GDPR Art. 33–34	NIS2 Art. 23
Trigger	Personal-data breach	Significant cyber incident
First deadline	72 h notification to DPA	24 h early warning to CSIRT
Audience	DPA, data subjects	CSIRT / competent authority, recipients of services, public
Question asked	Were data-subject rights at risk?	Were services and infrastructure resilient?

A ransomware incident on a hospital can simultaneously trigger NIS2 (essential entity, severe operational disruption) and GDPR (special-category personal-data breach). Two reports, two deadlines, two regulators – one incident.

Governance and Personal Liability



Art. 20: management is personally on the hook

Article 20 NIS2 reframes cybersecurity as a **governance** matter, not a delegated technical function.

Management bodies of essential and important entities must:

- **Approve** the risk-management measures taken to comply with Art. 21
- **Oversee** their implementation
- **Be held liable** for infringements by the entity
- **Follow training** to gain sufficient knowledge to identify risks and assess cybersecurity practices
- **Offer similar training** to their staff on a regular basis

Art. 20: management is personally on the hook

Article 20 NIS2 reframes cybersecurity as a **governance** matter, not a delegated technical function.

Management bodies of essential and important entities must:

- **Approve** the risk-management measures taken to comply with Art. 21
- **Oversee** their implementation
- **Be held liable** for infringements by the entity
- **Follow training** to gain sufficient knowledge to identify risks and assess cybersecurity practices
- **Offer similar training** to their staff on a regular basis

Management body includes the board of directors and any equivalent governing body. In Italy this typically maps to the **Consiglio di Amministrazione**, plus C-level executives where applicable.

What *board accountability* looks like in practice

To make Art. 20 auditable, an organization typically produces:

- A **board-approved information-security policy**, refreshed at least annually
- **Minutes** showing periodic review of risk register, incident summary, KPIs/KRIs
- A **decision log** for key cybersecurity investments and risk-acceptance decisions
- **Training records** for management members and staff
- A **clear delegation chart**: CISO, DPO, business owners, internal audit
- **Reporting lines** between the CISO and the board (direct or via audit/risk committee)

Sanctions targeting individual managers

Art. 32(5) and Art. 34 NIS2 allow Member States to apply, for **essential entities**, sanctions that go beyond the entity itself:

- **Temporary suspension** of the natural person responsible from managerial functions at CEO or legal-representative level
- **Temporary prohibition** of the entity from being authorised to provide services in regulated sectors
- These measures are typically a **last resort**, after corrective orders have been ignored

The combination of (i) personal liability, (ii) potential suspension and (iii) turnover-based fines is precisely what changes board-level behavior.

Sanctions targeting individual managers

Art. 32(5) and Art. 34 NIS2 allow Member States to apply, for **essential entities**, sanctions that go beyond the entity itself:

- **Temporary suspension** of the natural person responsible from managerial functions at CEO or legal-representative level
- **Temporary prohibition** of the entity from being authorised to provide services in regulated sectors
- These measures are typically a **last resort**, after corrective orders have been ignored

The combination of (i) personal liability, (ii) potential suspension and (iii) turnover-based fines is precisely what changes board-level behavior.

This is why NIS2 is sometimes called *the GDPR of cybersecurity*. The structural innovation is not the technical content – it is making sure the people allocating budget actually feel the risk.

Supervision, Sanctions, Cooperation



Two supervision regimes

Essential entities – *ex-ante* (Art. 32)

Competent authorities can act **without** evidence of non-compliance:

- on-site **inspections** and off-site supervision
- **regular and targeted security audits**
- **ad-hoc audits** (e.g., after sectoral incidents)
- **security scans** of public-facing assets
- requests for information, data, and evidence of policies

Important entities – *ex-post* (Art. 33)

Competent authorities act **when there is evidence**, an indication, or a complaint that the entity is not complying:

- inspections after incidents or whistleblower reports
- targeted audits triggered by indications of non-compliance
- requests for information and evidence
- in practice, lighter routine pressure than essential entities

Powers of the competent authority

Beyond inspections, NIS2 (Arts. 32–33) gives authorities a graded toolbox of **corrective measures**:

- Issue **warnings** about identified infringements
- Adopt **binding instructions** to remedy deficiencies or incidents
- Order to **inform users** of services about a significant cyber threat
- Order **implementation of recommendations** from a security audit
- Designate a **monitoring officer** to oversee compliance over a defined period
- Order to **make public aspects** of the infringement
- Impose or request a court to impose **administrative fines**
- For essential entities: temporary **suspension of management** or **certifications/authorisations**

Administrative fines

Art. 34 fixes the maximum administrative fines, calculated on **worldwide annual turnover** of the preceding financial year:

Category	Maximum fine
Essential entities	the higher of €10,000,000 or 2% of total worldwide annual turnover
Important entities	the higher of €7,000,000 or 1.4% of total worldwide annual turnover

Member States may set higher national maxima. The actual fine must be **effective, proportionate, and dissuasive**, taking into account: gravity, duration, intent vs negligence, prior infringements, cooperation, and damage caused.

Cooperation at EU level

Strategic & policy

- **NIS Cooperation Group:** Member States, Commission, ENISA – strategic cooperation, peer reviews, sector guidelines
- **ENISA:** technical guidance, EU vulnerability database (Art. 12), biennial *State of Cybersecurity in the Union* report

Operational

- **CSIRTs Network:** information sharing, coordinated response to cross-border incidents
- **EU-CyCLONe** (European Cyber Crisis Liaison Organisation Network): coordinated response to **large-scale incidents and crises** at operational/political level
- Mandatory **peer reviews** between national authorities (every 2 years)

NIS2 vs Other EU Cyber Laws



NIS2 vs GDPR: the same incident, different lenses

	GDPR	NIS2
Type	Regulation (directly applicable)	Directive (national transposition)
Object	Personal data of natural persons	Network and information systems
Trigger	Any processing of personal data	Operating in scoped sectors above size thresholds
Authority	National DPAs, EDPB	National competent authorities, CSIRTs, ENISA
Reporting	72 h to DPA, individuals if high risk	24 h / 72 h / 1 month to CSIRT, recipients, public
Maximum fine	€20M / 4% turnover	€10M / 2% turnover (essential)

NIS2 vs DORA, CER, CRA

NIS2 is **horizontal**. Several **lex specialis** regimes carve out specific sectors or layers:

- **DORA** (Reg. (EU) 2022/2554): financial entities follow DORA for ICT risk management and incident reporting; NIS2 obligations on those areas are replaced by DORA equivalents (Art. 4 NIS2)
- **CER Directive** (2022/2557): covers **physical resilience** of critical entities (energy, transport, banking, health, water, digital infra, public administration, space, food). Same scope as NIS2 essential entities for many sectors – NIS2 = cyber, CER = physical
- **CRA** (Cyber Resilience Act): obligations on **products with digital elements** (manufacturers). NIS2 still applies to the **operators** that *use* those products – not the same entities, not the same duties

NIS2 vs DORA, CER, CRA

NIS2 is **horizontal**. Several **lex specialis** regimes carve out specific sectors or layers:

- **DORA** (Reg. (EU) 2022/2554): financial entities follow DORA for ICT risk management and incident reporting; NIS2 obligations on those areas are replaced by DORA equivalents (Art. 4 NIS2)
- **CER Directive** (2022/2557): covers **physical resilience** of critical entities (energy, transport, banking, health, water, digital infra, public administration, space, food). Same scope as NIS2 essential entities for many sectors – NIS2 = cyber, CER = physical
- **CRA** (Cyber Resilience Act): obligations on **products with digital elements** (manufacturers). NIS2 still applies to the **operators** that *use* those products – not the same entities, not the same duties

For a hospital: NIS2 (cyber resilience as essential entity) + CER (physical resilience) + GDPR (patient data) + CRA-driven requirements on the medical devices it buys + sectoral health rules. NIS2 is one of *many* simultaneous obligations.

Mapping the cyber stack at a glance

Question	Main instrument
Is personal data lawfully processed and protected?	GDPR + ePrivacy
Does the organization run cybersecurity as a covered entity should?	NIS2 (DORA for finance)
Is the physical infrastructure resilient?	CER
Are products placed on the market secure-by-design?	CRA
Are AI systems governed proportionally to their risk?	AI Act
Is there an EU-wide certification scheme for trust?	Cybersecurity Act + ENISA schemes

NIS2 Compliance in Practice



A realistic NIS2 compliance roadmap

1. **Scoping**: confirm whether the entity is essential, important, or out of scope; check national lists
2. **Registration** with the national competent authority within the deadlines
3. **Gap analysis** against Art. 21 (typically using ISO 27001 / NIST CSF as control catalogues)
4. **Governance**: board approval of the security policy, training plan, decision logs
5. **Risk-treatment plan**: investments, deadlines, owners, residual-risk acceptance
6. **Incident-response readiness**: 24h/72h/1m playbooks, CSIRT contact, evidence preservation
7. **Supply-chain**: critical-supplier register, contract clauses, monitoring
8. **Effectiveness** (Art. 21(2)(f)): KPIs/KRIs, audits, pen tests, exercises
9. **Continuous improvement**: management reviews, lessons learned, annual policy refresh

Common pitfalls

- **"NIS2 = ISO 27001 certificate"**: certification helps, but does not by itself prove compliance with Art. 21 or with national reporting duties
- **"It's the CISO's problem"**: Art. 20 explicitly puts the burden on the management body
- **Reporting only after root-cause analysis**: by then the 24h and 72h deadlines are gone
- **No evidence trail**: controls exist but cannot be demonstrated under audit
- **Ignoring the supply chain**: most reportable incidents have a third-party component
- **Underestimating proportionality**: small in-scope entities still need *all* ten Art. 21 categories, just calibrated
- **Treating GDPR and NIS2 as one workflow**: different audiences, different deadlines, different evidence

Worked example: ransomware on a regional water utility

Scenario: a ransomware group encrypts the SCADA management network and the corporate IT of a regional water utility serving 600,000 inhabitants. Drinking water supply is degraded for 36 hours.

Why NIS2 applies:

- *Drinking water* is in **Annex I** → essential entity (size-cap met)
- Severe operational disruption + impact on natural persons → **significant incident**

What the utility must do:

- **t = 0** (awareness): activate IR plan, isolate SCADA, preserve evidence
- **+24h**: early warning to CSIRT (suspected ransomware, possible cross-border impact via shared aquifer authority)
- **+72h**: notification with initial impact assessment
- **+ promptly**: notify recipients (consumers, municipality) about the cyber threat and mitigation advice
- **+1 month**: final report with root cause and remediation

Worked example: ransomware on a regional water utility

Scenario: a ransomware group encrypts the SCADA management network and the corporate IT of a regional water utility serving 600,000 inhabitants. Drinking water supply is degraded for 36 hours.

Why NIS2 applies:

- *Drinking water* is in **Annex I** → essential entity (size-cap met)
- Severe operational disruption + impact on natural persons → **significant incident**

What the utility must do:

- **t = 0** (awareness): activate IR plan, isolate SCADA, preserve evidence
- **+24h**: early warning to CSIRT (suspected ransomware, possible cross-border impact via shared aquifer authority)
- **+72h**: notification with initial impact assessment
- **+ promptly**: notify recipients (consumers, municipality) about the cyber threat and mitigation advice
- **+1 month**: final report with root cause and remediation

Personal data is processed by the billing system. If billing was also affected, **GDPR Art. 33** (72 h to DPA) is triggered in parallel. Two regulators, one incident.

Italian operational specifics

Under D.Lgs. 138/2024 and ACN guidelines:

- **Self-assessment & registration** on the ACN platform (annual maintenance window: typically January–February)
- **Notification channel: CSIRT Italia** for incident reports (24h / 72h / 1m)
- **ACN determinations** specify minimum security measures and proportionality criteria
- **Sectoral authorities** (e.g., Bank of Italy, ARERA, AGCOM) cooperate with ACN for sector-specific oversight
- **Sanctions:** same NIS2 maxima, plus Italian-specific accessory measures and an injunction-based enforcement style
- **Public administration** (central and regional) is explicitly in scope as essential entity

Takeaways



What you should retain from this lecture

- NIS2 is the EU's **horizontal cybersecurity law** for organizations society depends on
- Two categories – **essential** and **important** – same obligations, different supervision and fines
- **Article 21** fixes a minimum content for the cybersecurity programme; **Article 23** fixes the reporting timeline (24 h / 72 h / 1 month)
- **Article 20** makes **management personally accountable** – including suspension for essential entities
- NIS2, GDPR, DORA, CER, and CRA are **complementary**: the same incident can trigger several at once
- In Italy, the relevant text is **D.Lgs. 138/2024**, supervised by **ACN**, with notifications to **CSIRT Italia**